MVP Dagen

Når den digitale arbeideren lekker virksomhetens data



Roy Allan Hansen

Microsoft MVP Security (Purview)

Sjefskonsulent, Move AS

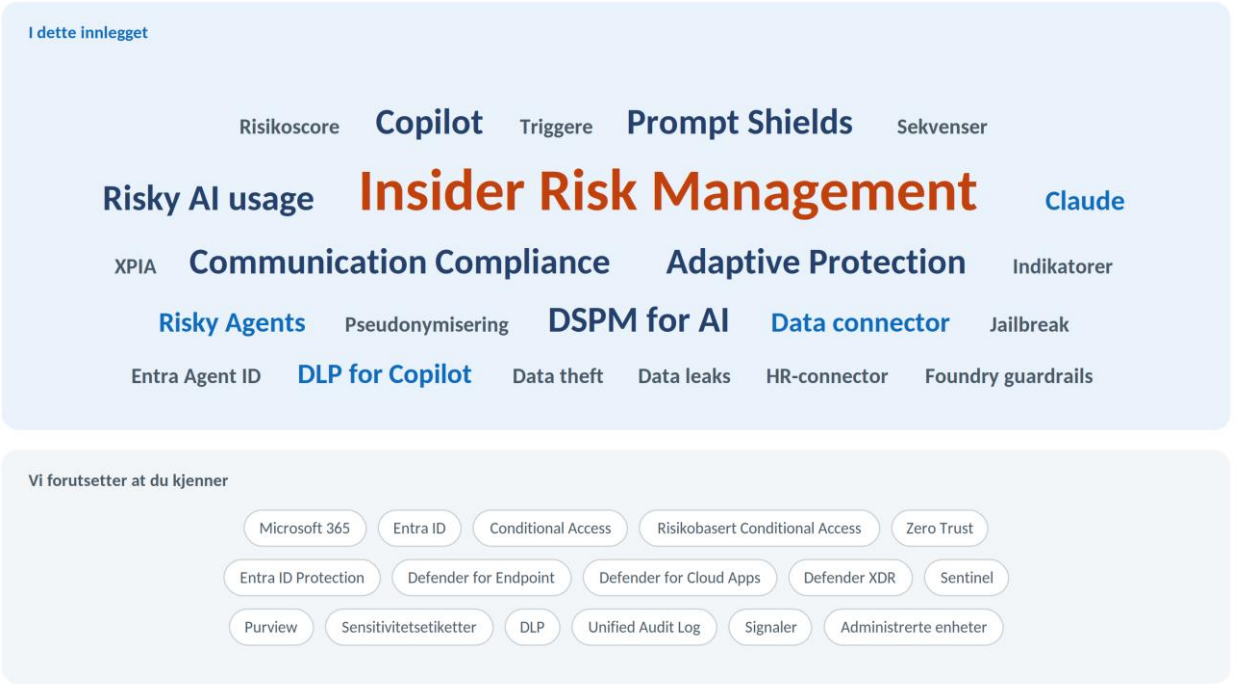
MVP Dagen #MVPDagen

1

Agenda

Innsiderisiko	Insider Risk Management	Risikabel bruk av KI	Kontroll og personvern
• Hvem er innsidetrusselen? • Indikatorer på innsiderisiko • Sekvenser av indikatorer	• Fra siloer til helhetlig risikostyring • Signalflyt og policyer • Dataeksfiltrering	• Hvordan KI endrer risikobildet • IRM og DSPM • Prompt Shields og agenter • Claude Enterprise	• Adaptiv beskyttelse • Hvordan ivareta personvernet

2



3

Innsiderisiko

Innsidetrusselen, indikatorer på innsiderisiko, sekvenser av indikatorer

4

Innsidetrusselen

- En innsider er en *nåværende eller tidligere ansatt*, konsulent eller kontraktør som har eller har hatt legitim tilgang til virksomhetens systemer, prosedyrer, objekter og informasjon, og som *misbruker denne kunnskapen og tilgangen til å påføre virksomheten skade eller tap*.
- Dette er ikke et *inntrengingsproblem*, det er et *tillitsproblem*, og derfor treffer de tradisjonelle sikkerhetskontrollerne dårlig.

- ...og den kan selvfølgelig også være en KI-agent.



5

Innsidetrusselen

- Den typiske innsidetrusselen er:
  - En fast ansatt
  - Mann i alderen 30-45 år
  - Høyere utdanning
  - Arbeider innenfor områder som sikkerhet, salg, kundeservice eller økonomi
  - Ansatt i mindre enn 5 år

- De fleste selvrekrutterer seg selv til rollen som innsider over tid, ofte i kombinasjon med personlige, økonomiske eller organisatoriske stressfaktorer.

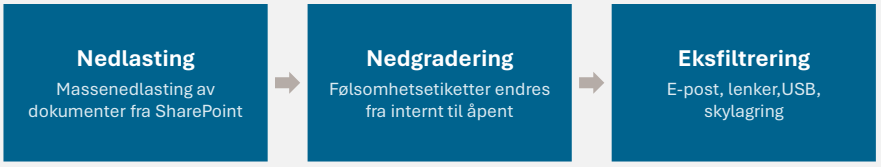
6

Indikatorer på innsiderisiko

- Typiske tekniske indikatorer på forhøyet innsiderisiko er:
  - Sender sensitiv informasjon til eksterne mottakere via e-post
  - Logger på utenfor normale arbeidstider
  - Gjør uvanlige eller gjentatte søk etter sensitiv informasjon
  - Laster ned store datamengder som ikke er relevante for rollen
  - Kopierer eller samler filer fra sensitive områder
  - Nedgraderer eller avklassifiserer dokumenter
  - Forsøker å omgå eller deaktivere sikkerhetskontroller
  - Bruker uautoriserte lagringsenheter
  - Forsøker jailbreak eller prompt injection mot KI-assistenter
  - Limer inn eller laster opp sensitive data til generative KI-tjenester på nett

7

Sekvenser av indikatorer er forsterkere



8

Insider Risk Management

Arbeidsflyt, signalflyt og policyer

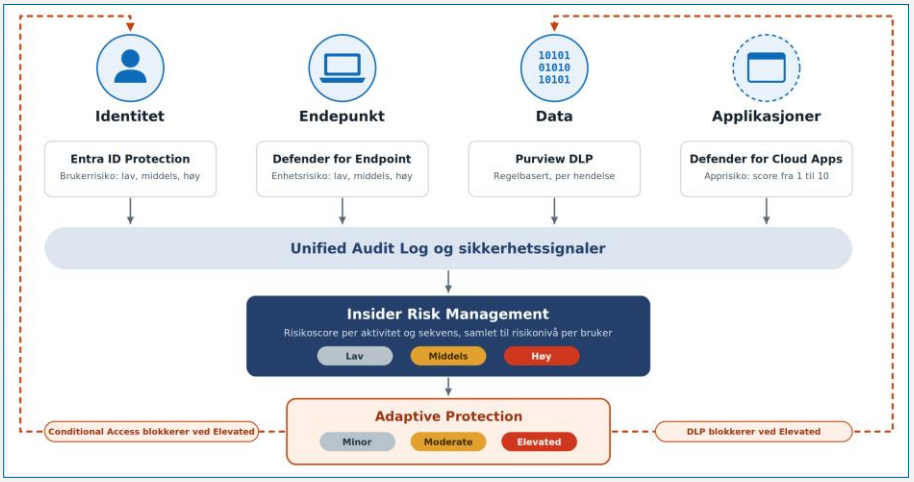
9

Insider Risk Management

- En av mange løsninger i Microsoft Purview (en admin portal tilgjengelig for virksomheter med M365 lisenser).
- Har over tid hatt forholdsvis liten utbredelse i Norge, men har fått en boost de senere årene som følge av at virksomheter har tatt i bruk KI-assistenter.
- Tilgjengelig for virksomheter med Purview Suite, E5 og E7 lisenser.
- Dette lisensnivået gir tilgang på de viktigste løsningene i Purview som brukes for å regulere bruken av KI-assistenter:
  - DLP – Data Loss Prevention
  - IRM – Insider Risk Management
  - CC – Communication Compliance
  - DSPM – Data Security Posture Management

10

Insider Risk Management



11

Insider Risk Management – typiske policyer

Datatyveri ved fratredelse	Datalekkasjer	Risikabel KI-bruk	Risikabel nettleserbruk	Brudd på sikkerhetspolicyer
HVEM Ansatte som slutter TRIGGER HR-Connector AKTIVITETER - Massenedlasting fra SharePoint - Utskrift av filer - Kopiering til privat skylagring	HVEM Alle ansatte TRIGGER DLP-treff eller eksfiltrering AKTIVITETER - Deling med eksterne - Kopiering til USB - Kopiering til privat skylagring	HVEM KI-brukere TRIGGER Risikabel aktivitet i KI-apper AKTIVITETER - Risikable prompter - Sensitive svar - Skygge-KI	HVEM Alle ansatte TRIGGER Besøk på risikable nettsider AKTIVITETER - Kriminell virksomhet - Hat og intoleranse - Pornografi	HVEM Enheter i Defender TRIGGER Varsel fra Defender for Endpoint AKTIVITETER - Deaktivering av defender etc - Installasjon av uønsket programvare

12

Insider Risk Management

Vi setter opp en IRM policy for dataeksfiltrering - DEMO

Insider Risk Management

Vi trigger policyen som en innsidetrussel - DEMO

Insider Risk Management

Vi behandler varselet - DEMO

Insider Risk Management

Risikabel bruk av KI

KI øker risikobildet

40 %

av alle KI-interaksjoner involverer sensitive data, i hovedsak fra ansatte uten skadehensikt

92 %

prosent sier KI har endret hvordan ansatte deler informasjon.

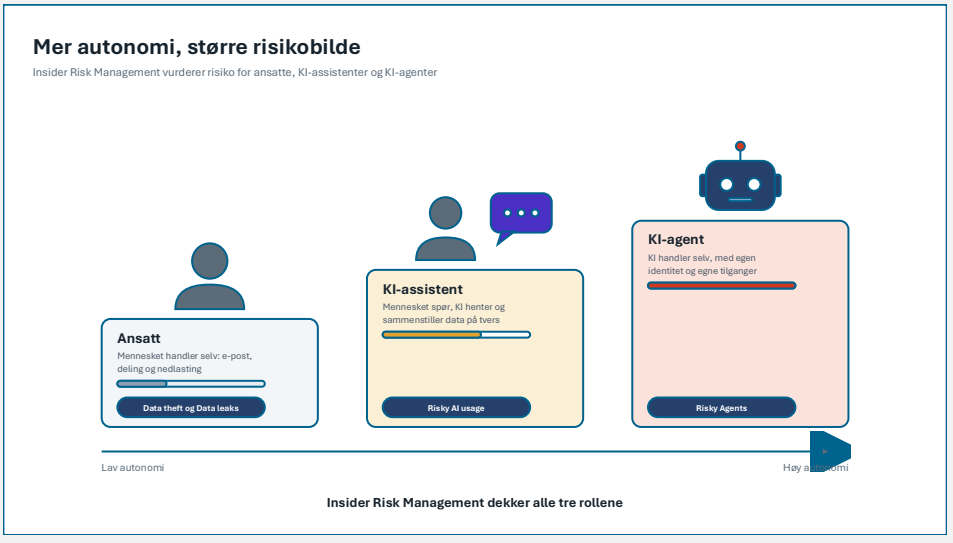
15 %

av brukerne i en gjennomsnittsvirksomhet har uautoriserte KI-utvidelser i nettleseren

Kilder: Cyberhaven Labs 2026, DTEX Insider Threat Report 2026, Verizon DBIR 2026

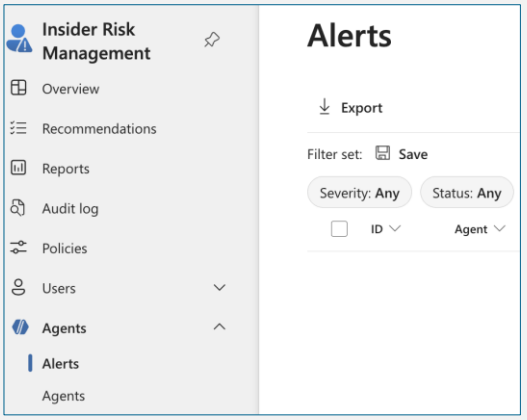
17

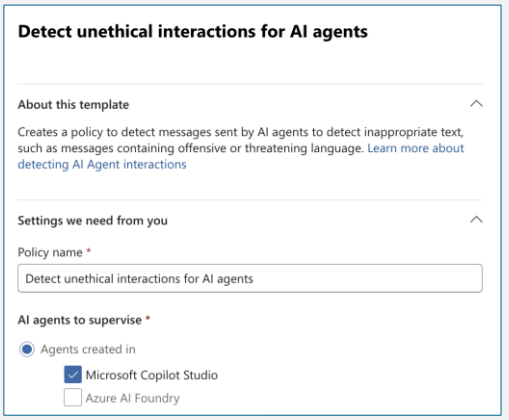
KI øker risikobildet



18

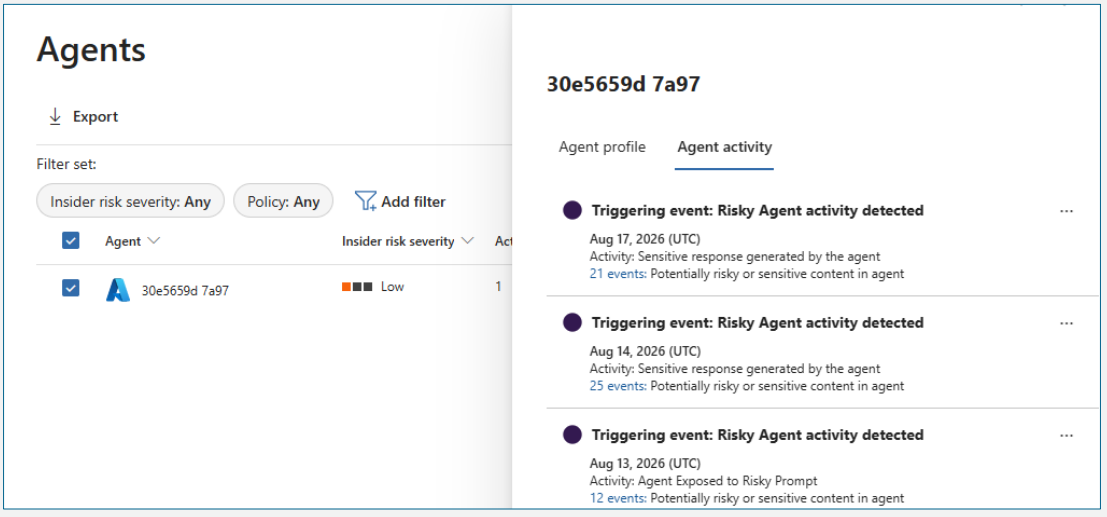
Microsoft Copilot – KI-agenter





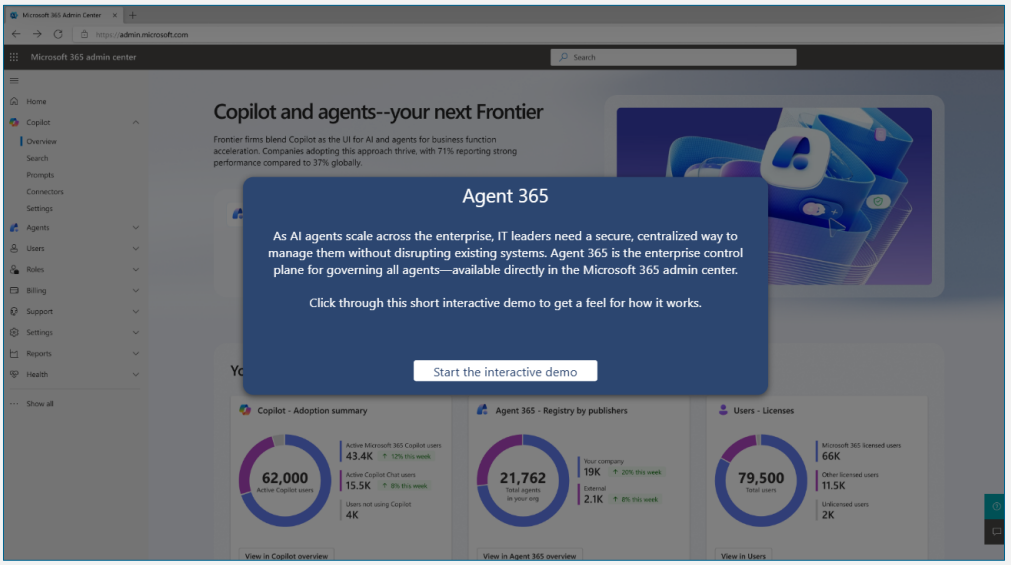
19

Microsoft Copilot – KI-agenter



20

Microsoft Copilot – KI-agenter



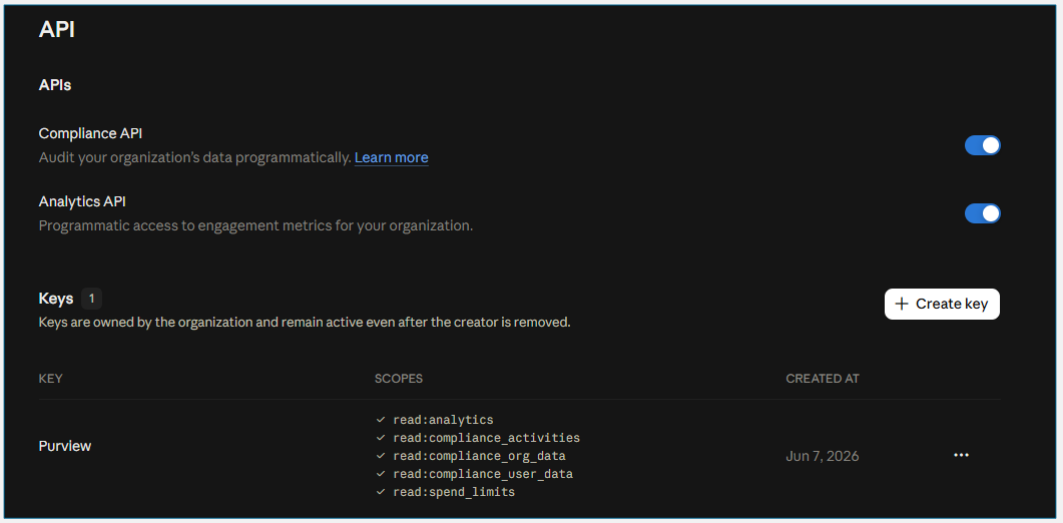
21

Insider Risk Management

Kontrollpotensialet for Claude Enterprise

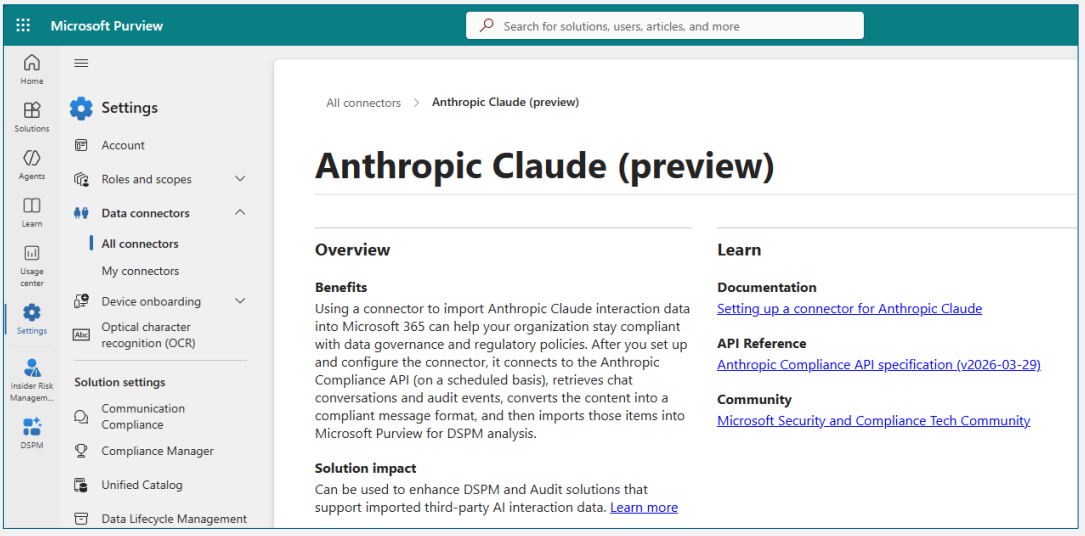
22

Claude Enterprise



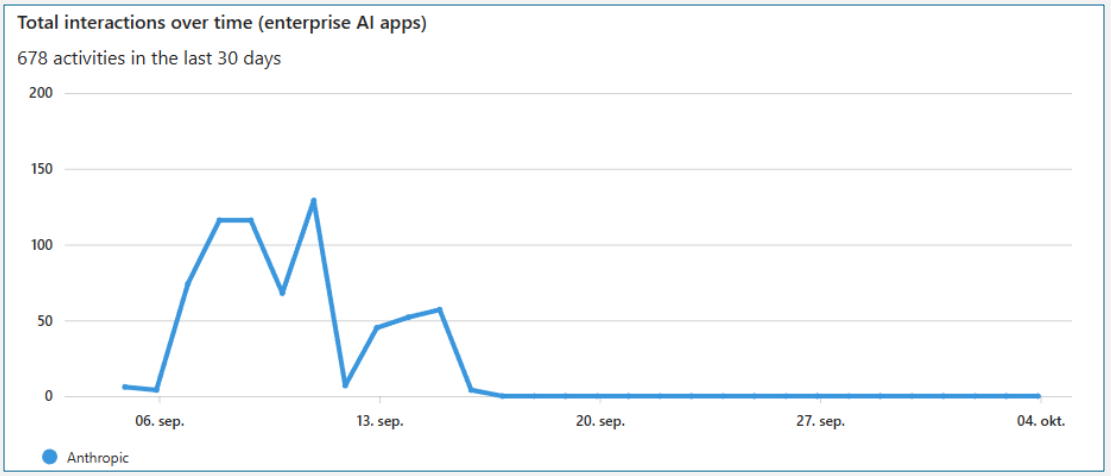
23

Claude Enterprise



24

Claude Enterprise



25

Claude Enterprise

Capability or solution in Microsoft Purview	Supported for AI interactions
DSPM and DSPM for AI (classic)	✓
Auditing	✓
Data classification	✓
Sensitivity labels	✗
Encryption without sensitivity labels	✗
Data loss prevention	✗
Insider Risk Management	✓
Communication compliance	✓
eDiscovery	✓
Data Lifecycle Management	✓
Compliance Manager	✓

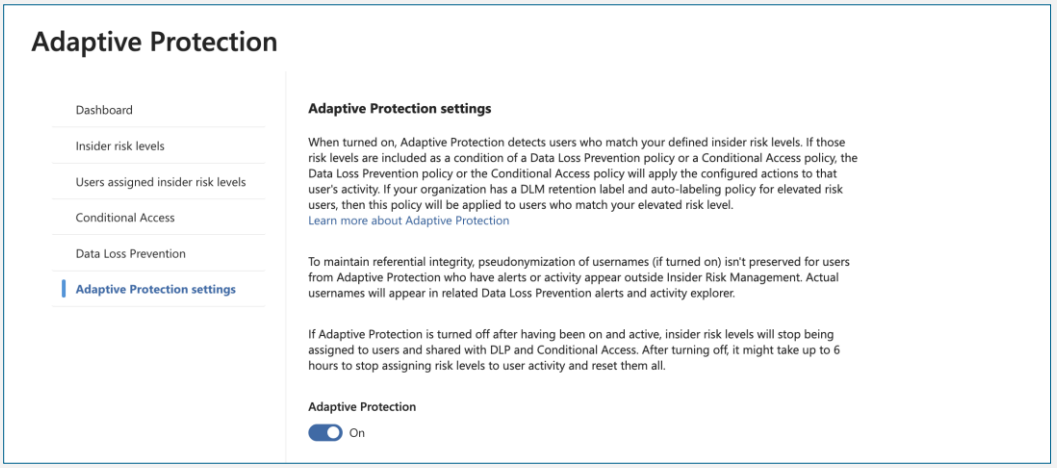
26

Adaptiv beskyttelse

Vi kobler sammen IRM, DLP og CA

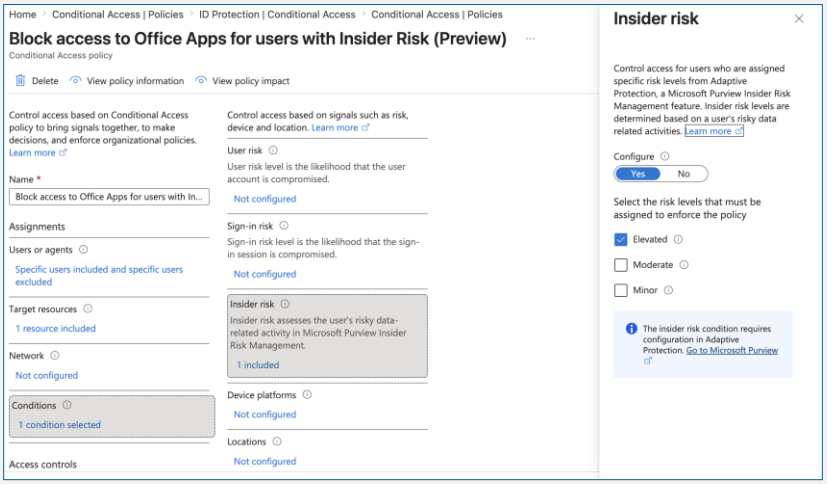
27

Adaptiv beskyttelse



28

Adaptiv beskyttelse



29

Hva med personvernet?

… dette er jo overvåking?

30

Hvordan ivareta personvernet

- E-postforskriften
- Arbeidsmiljøloven kapittel 9: saklig grunn, forholdsmessighet og drøfting med tillitsvalgte
- Risikovurderinger (ROS og DPIA)
- Risikohåndtering (tiltak for å redusere risiko)
- Pseudonymisering
- Informasjon til ansatte

31

Hvordan ivareta personvernet



32

Hvordan ivareta personvernet

Vi vurderer det slik at en DPIA som hovedregel vil kreves ved bruk av generative KI-verktøy slik som M365 Copilot i forbindelse med behandling av personopplysninger, ettersom «bruk av ny teknologi» er fremhevet som en særlig viktig faktor, og forståelsen av risiko knyttet til generativ KI ennå er umoden. Å gjennomføre en eller flere DPIA-er, uansett om det er påkrevd eller ikke, vil hjelpe NTNU å vurdere spesifikke risikoer og sannsynligheten for slike risikoer i en gitt kontekst. Det vil også bidra til å belyse det NTNU ikke vet om enten produktet, teknologien eller forutsetningene for teknologien sett i sammenheng med en bestemt behandling (f.eks. for å kunne vurdere om en har god nok «orden i eget hus»). Det vil også bidra til å påvise etterlevelse av ansvarsprinsippet etter personvernforordningen artikkel 5 nr. 2.

33

Hvordan ivareta personvernet

Samlet sett anser vi det som sannsynlig at samhandlingsloggen vil kunne rammes av forbudet mot overvåking av arbeidstakers bruk av elektronisk utstyr i e-postforskriften § 2 andre ledd. For at samhandlingsloggen skal kunne opprettes lovlig, må formålene med samhandlingsloggen falle inn under ett av unntakene.

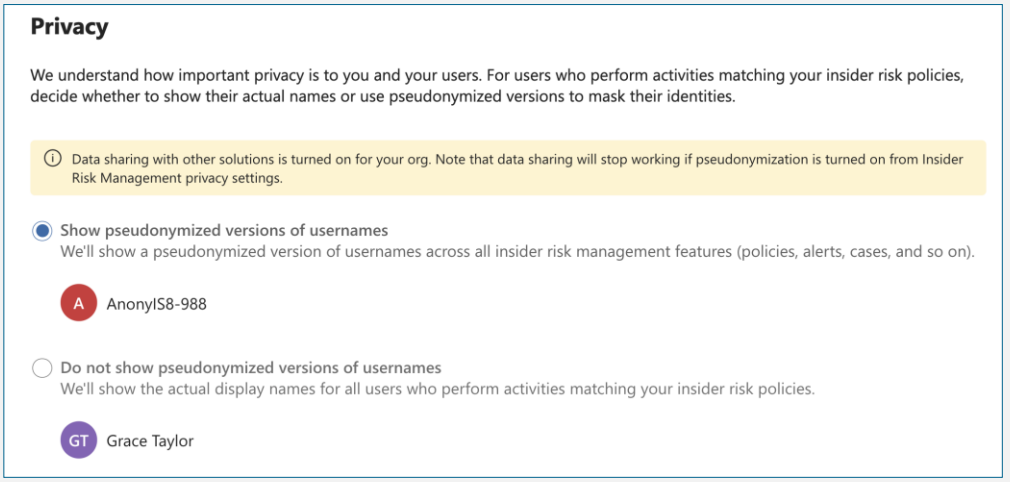
Unntak fra forbudet

Det ene unntaket kommer til anvendelse dersom formålet er å «administrere virksomhetens datanettverk». Dette forstår vi som alle praktiske og tekniske tiltak som er nødvendige for at systemene, nettverk, utstyr og programvare skal fungere.[45] Vi har forstått det slik at hovedformålet med samhandlingsloggen er å sikre at kvaliteten på tjenesten er slik den skal være. Ved å gå gjennom brukerens instrukser og M365 Copilots svar kan NTNU avdekke svakheter og forbedringspotensialer ved systemet. Mulige systematiske feilsvar kan bli fanget opp og rettet opp. Dette formålet kan falle inn under unntaket for å administrere virksomhetens datanettverk.

Det andre unntaket kan være aktuelt dersom formålet med samhandlingsloggen er å «avdekke eller oppklare sikkerhetsbrudd i nettverket». Med sikkerhetsbrudd forstår vi brudd på informasjonssikkerheten generelt. Det er vanlig å si at det handler om å sikre at informasjon ikke blir kjent for uvedkommende (konfidensialitet), ikke blir endret utilsiktet eller av uvedkommende (integritet) og er tilgjengelig ved behov (tilgjengelighet). Hvorvidt dette unntaket kommer til anvendelse må vurderes konkret opp mot hva som er formålet med samhandlingsloggen.

34

Hvordan ivareta personvernet



35